

Checklist RGPD pour Associations

Mise en conformité Règlement Général sur la Protection des Données — Biscuits IA 2026

Le RGPD s'applique à TOUTE association qui collecte ou traite des données personnelles de personnes physiques dans l'UE. Une mise en conformité n'est pas optionnelle : les amendes peuvent atteindre 2 % du budget annuel.

1. Cartographie des données (obligatoire)

- ☐ Tenir un Registre des Activités de Traitement (RAT) à jour
- ☐ Identifier toutes les données personnelles collectées (noms, e-mails, téléphones, santé...)
- ☐ Documenter la finalité de chaque traitement (pourquoi collectez-vous ces données ?)
- ☐ Identifier la base légale de chaque traitement (consentement, contrat, intérêt légitime...)
- ☐ Recenser tous les sous-traitants qui accèdent à vos données (hébergeur, CRM, prestataire...)
- ☐ Définir la durée de conservation pour chaque catégorie de données

2. Droits des personnes

- ☐ Informer les personnes lors de la collecte (politique de confidentialité accessible)
- ☐ Prévoir une procédure pour répondre aux demandes d'accès dans les 30 jours
- ☐ Permettre la rectification des données inexactes
- ☐ Permettre la suppression des données sur demande (droit à l'effacement)
- ☐ Permettre la portabilité des données (export dans un format lisible)
- ☐ Mettre en place un mécanisme de retrait du consentement simple et accessible

& Le consentement doit être libre, éclairé, spécifique et univoque. Une case pré-cochée est INVALIDE.

3. Sécurité des données

- ☐ Chiffrer les bases de données contenant des données personnelles
- ☐ Sauvegarder les données régulièrement (règle 3-2-1 : 3 copies, 2 supports, 1 hors site)
- ☐ Limiter l'accès aux données selon le principe du moindre privilège
- ☐ Tracer les accès aux données sensibles (journaux d'audit)
- ☐ Protéger les échanges d'e-mails contenant des données personnelles (chiffrement)
- ☐ Mettre à jour régulièrement tous les logiciels et plugins utilisés

4. En cas de violation de données

- ☐ Détecter et documenter tout incident touchant des données personnelles
- ☐ Notifier la CNIL dans les 72h si risque pour les personnes concernées
- ☐ Informer les personnes concernées si le risque est élevé
- ☐ Tenir un registre interne des violations (même celles non notifiées)
- ☐ Analyser les causes et mettre en place des mesures correctives

5. Contrats et sous-traitance

- ☐ Signer un DPA (Data Processing Agreement) avec chaque sous-traitant
- ☐ Vérifier que les sous-traitants hors UE offrent des garanties équivalentes
- ☐

Ne transférer des données hors UE que vers des pays adéquats ou avec des garanties (SCC)

☐ Vérifier les clauses RGPD dans les CGU des outils utilisés (Google, Mailchimp...)

6. Documents obligatoires

- ☐ Registre des Activités de Traitement (RAT)
- ☐ Politique de confidentialité publiée sur le site web
- ☐ Mentions légales complètes
- ☐ Mentions d'information lors de chaque collecte de données
- ☐ Contrats de sous-traitance avec les prestataires
- ☐ Analyses d'impact (AIPD) pour les traitements à risque élevé

Ressource officielle : cnil.fr/fr/les-outils-de-la-conformite — La CNIL propose des modèles de registre et de politique de confidentialité gratuits adaptés aux associations.

